

Muhammad Saad Salman

Sun, Feb 15, 2026

Intern Ultrasecure

OWASP Top 10:

Its top 10 classification of the vuln affecting the web apps.

It's a regular update list; a non profit org improving web security.

The list mostly contains the XSS, Session mgmt issues, and SQLi.

Top 10:2025 List

1. [A01:2025 - Broken Access Control:](#)

Failure to properly enforce authorization policies. Users can access resources or perform actions outside their privileges.

Examples

- IDOR (Insecure Direct Object Reference)
- Horizontal privilege escalation (user accessing another user's data)
- Vertical privilege escalation (user gaining admin access)
- Forced browsing of restricted endpoints

Mitigation

- Enforce **server-side authorization checks**
- Implement **RBAC/ABAC models**
- Deny by default
- Validate object ownership on every request

2. [A02:2025 - Security Misconfiguration](#)

Improperly configured application, server, database, or cloud environment.

Examples

- Default credentials
- Open S3 buckets
- Directory listing enabled
- Debug mode enabled in production
- Unnecessary services running

Mitigation

- Harden configurations
- Remove default accounts

- Automated configuration management
- Regular configuration audits

3. [A03:2025 - Software Supply Chain Failures](#)

Vulnerabilities introduced through third-party libraries, dependencies, CI/CD pipelines, or compromised packages.

Examples

- Malicious npm package
- Compromised Docker image
- Dependency confusion attacks
- Outdated vulnerable libraries

4. [A04:2025 - Cryptographic Failures](#)

Improper use of cryptography leading to exposure of sensitive data.

Examples

- Storing passwords in plaintext
- Using weak hashing (MD5, SHA1)
- Hardcoded encryption keys
- No HTTPS (TLS misconfiguration)

5. [A05:2025 - Injection](#)

Untrusted input is interpreted as code or commands.

Examples

- SQL Injection
- OS Command Injection
- LDAP Injection
- NoSQL Injection
- SSTI (Server-Side Template Injection)

6. [A06:2025 - Insecure Design](#)

Security flaws at the architectural or design level, not just implementation bugs.

Examples

- No rate limiting (brute force possible)
- Business logic flaws

- Missing threat modeling
- Insecure password reset flow

7. [A07:2025 - Authentication Failures](#)

Weak identity verification mechanisms.

Examples

- Weak password policies
- No MFA
- Session fixation
- Predictable session IDs
- Credential stuffing vulnerability

8. [A08:2025 - Software or Data Integrity Failures](#)

Trusting code or data without verifying integrity.

Examples

- Deserialization attacks
- Unsigned software updates
- CI/CD pipeline tampering
- Auto-update without integrity checks

9. [A09:2025 - Security Logging and Alerting Failures](#)

Insufficient logging, monitoring, and incident detection capabilities.

10. [A10:2025 - Mishandling of Exceptional Conditions](#)

Improper handling of errors, edge cases, or abnormal system states.

Examples

- Stack traces exposed to users
- Unhandled exceptions crashing app
- Detailed SQL errors leaked
- Fail-open behavior during error

